

MALTA MICROSOFT AI USER GROUP

MMAUG Secure Login Portal — Updated Technical Proposal

Response: MMAUG-AIDB-RFP-002
Version: 4.0 — Single managed identity, Application Gateway WAF, and approved database
Date: 9 November 2026

Executive proposal

The proposed solution delivers a secure school portal for students, teachers, and administrators using a React frontend, a FastAPI protected API, and PostgreSQL. Microsoft Entra authenticates users, while the application database independently determines whether an identity is enrolled, active, and authorized for a portal role.

The development platform will use the approved Azure App Service Plan, Azure Database for PostgreSQL Flexible Server B1ms, and Azure Application Gateway WAF_v2. Application Gateway provides the public HTTPS entry point and applies OWASP 3.2 managed rules in Prevention mode before routing requests to the frontend or API.

Approved Azure architecture

Area	Approved design
Azure scope	Tenant `71beefd7-29f4-4b9e-9cb2-e78b5dc851ad`, resource group `rg_mmaug_high_school`, North Europe
Managed identity	One UAMI: `id-mmaug-secure-login-portal`
CI/CD authentication	GitHub Actions OIDC with the exact `development` environment subject; no client secret
Public entry point	Application Gateway WAF_v2 with HTTP-to-HTTPS redirect
DNS proposal	`mmaug-secure-portal.northeurope.cloudapp.azure.com`
Application hosting	One Linux B1 App Service Plan hosting separate frontend and API Web Apps
Database	Private PostgreSQL Flexible Server `B_Standard_B1ms` for development
Secrets and certificates	Key Vault references and access policies; secrets are not committed to source or copied into application settings

Area	Approved design
Monitoring	Workspace-based Application Insights and Log Analytics

Azure reported the proposed DNS label as available on 9 November 2026. Availability is not a reservation; Terraform reserves it when the gateway Public IP is created.

Identity and access

The portal uses the Microsoft identity platform `common` authority so Microsoft work, school, guest, and personal accounts can authenticate. The SPA uses authorization code with PKCE and requests the API's delegated `access_as_user` scope. No SPA or API client secret is created.

Successful Microsoft authentication does not automatically grant portal access. FastAPI validates the token and resolves the immutable `(tenant ID, object ID)` pair against the PostgreSQL enrollment record. Unenrolled and inactive identities receive no portal data. Student, teacher, and administrator authorization remains server-side.

The single approved managed identity performs these approved duties:

- GitHub OIDC deployment to the project resource group;
- workload identity for the API and Application Gateway;
- retrieval of authorized Key Vault values; and
- temporary Microsoft Graph bootstrap of the SPA/API registrations and their Enterprise Applications, subject to separate Entra administrator consent.

Because one identity combines deployment and runtime duties, the GitHub `development` environment must use protected branches and required reviewers. Broad Microsoft Graph bootstrap permissions should be removed after the final app registrations, consent, and redirect URI are verified.

Network and WAF controls

Application Gateway terminates public TLS, redirects HTTP to HTTPS, and maintains HTTPS to both App Service backends. Requests under `/api/*` go to FastAPI; all other paths go to the React SPA. The WAF uses the OWASP 3.2 managed ruleset in Prevention mode with request-body inspection enabled.

PostgreSQL has no public endpoint and uses a delegated VNet subnet and private DNS. The API reaches the database through VNet integration. Application telemetry is sent to Application Insights without granting portal users Azure access.

Managed identity removes the Entra client-secret requirement. It does not eliminate the cryptographic material needed for HTTPS. Application Gateway requires a trusted certificate containing a private key. The proposal references that certificate from Key Vault so it is not embedded in source control, workflow artifacts, or Terraform input. The development vault uses access policies so the Contributor-only deployment does not need permission to create Azure role assignments; production should revisit separation of duties and the Azure RBAC model.

Delivery and acceptance

Source implementation, automated tests, Terraform, Entra bootstrap automation, and GitHub deployment workflows are maintained in the project repository. Live acceptance requires the following sequence:

1. An Entra administrator confirms the managed identity's approved Microsoft Graph bootstrap permission and tenant-wide consent authority.
2. A trusted TLS certificate is issued for the final DNS hostname and imported into Key Vault with managed-identity read access.
3. Terraform deploys the approved development resources.
4. The Entra bootstrap workflow creates the API and SPA registrations without client secrets and records the final HTTPS redirect URI.
5. Eight synthetic demonstration identities are mapped to their real Entra tenant and object IDs in PostgreSQL.
6. Acceptance tests verify sign-in, deny-by-default enrollment, role isolation, WAF, audit events, recovery, monitoring, and absence of credentials from the repository.

Real student data remains prohibited until privacy assessment, retention, backup and restore, penetration testing, Conditional Access, incident response, and operational ownership are separately approved.